

百融统一登录认证授权中心产品需求说明书

1. 项目概述

1.1 项目背景

新版百融官网升级后，将承担百系产品统一入口职能。官网不仅作为品牌展示与产品导航入口，同时需逐步承接百系产品统一注册、统一登录、统一认证与统一身份识别能力。

当前百系产品存在独立登录入口、独立账号体系、独立认证方式，用户从官网进入不同产品时存在重复登录、身份割裂、状态不统一等问题，官网无法形成统一用户承接链路。

因此需建设统一登录认证授权中心，作为官网统一身份基础设施，对内输出标准化认证能力，对外形成统一登录入口。

1.2 项目目标

建设统一登录认证授权中心，实现：统一注册、统一登录、统一认证、统一授权、统一身份标识、单点登录（SSO）、单点登出（SLO）、官网统一入口能力。

2. 产品定位

2.1 核心职责

统一登录认证授权中心负责：用户注册、用户登录、统一登录认证授权、统一 UID 管理、票据签发、UserInfo 服务、SSO、SLO、登录审计。

2.2 职责边界

统一认证中心负责身份层统一，不替代各产品业务系统。

各产品继续负责：本地账号、本地 Session、租户、角色、菜单、数据权限、业务权限。

3. 建设原则

3.1 统一认证，产品自治

统一登录认证授权中心负责统一身份识别与认证授权，各产品保留自身账号体系及权限体系。

3.2 渐进式推进

允许各产品保留现有登录方式作为过渡入口，但统一认证中心逐步成为官网主登录链路。

4. 用户模型

4.1 C端用户

个人用户统一注册与登录。

4.2 B端用户

企业管理员、企业成员。

4.3 B+C混合身份用户

支持同一用户在统一身份下承载多身份场景。

5. 总体架构

官网统一入口 → 统一登录认证授权中心 → 百系产品 → 本地账号映射 + 产品权限体系

6. 核心机制设计

6.1 Unified UID

所有用户在统一认证中心内拥有唯一身份标识（Unified UID）。

6.2 本地账号映射

统一认证中心不直接替代各产品本地账号体系，各产品通过 Unified UID 与本地账号建立映射关系。

映射关系：Unified UID ↔ Local User ID

6.3 首次绑定机制

用户首次通过官网进入产品时：已存在本地账号则绑定本地账号；不存在本地账号则创建本地账号；存在冲突则进入冲突处理流程。

7. 核心业务流程

7.1 官网登录

用户在官网完成统一注册或登录后，建立统一身份状态。

7.2 官网进入产品

官网 → 统一认证中心 → 产品侧 → 本地 Session

目标：官网登录后进入产品免二次登录。

7.3 产品直接访问

产品 → 统一认证中心 → 登录 → 回跳产品

8. 登录体验要求

用户登录一次后，可访问已接入产品；官网进入产品无需重复登录；登录状态统一；首次绑定标准化；登录异常可控。

9. 登出机制

9.1 本地登出

仅退出当前产品，不影响官网及其他产品登录状态。

9.2 全局登出

退出统一认证中心，同时清理官网及接入产品登录状态。

10. 安全规范

10.1 redirect_uri

所有 redirect_uri 必须统一白名单管理。

10.2 state

所有授权请求必须校验 state，防止 CSRF。

10.3 Token 安全

access_token / refresh_token 禁止暴露于前端或 URL。

10.4 client_secret

仅允许服务端保存。

10.5 HTTPS

生产环境必须全链路 HTTPS。

10.6 日志安全

日志必须脱敏处理，不记录敏感信息。

11. 标准输出能力

统一登录认证授权中心需向各产品提供：client_id、client_secret、redirect_uri 配置、logout_uri 配置、访问的票据、UserInfo、SSO、SLO、登录审计能力。

12. 产品接入要求

接入产品需满足：支持统一认证中心登录、支持官网免二次登录、支持 Unified UID 映射、支持首次绑定、支持本地登出、支持全局登出、满足统一安全规范。

13. 非建设范围

本项目不包含：统一产品业务权限、统一租户体系、统一角色体系、统一菜单体系、统一账号库合并。

14. 验收标准

15.1 功能验收

官网统一注册登录完成；官网进入产品免二次登录；Unified UID 生效；首次绑定流程可用；SSO 生效；SLO 生效。

15.2 安全验收

redirect_uri 白名单；state 校验；token安全；client_secret 安全；HTTPS；日志脱敏。